BÁO CÁO ĐỒ ÁN — HỆ THỐNG IAM THEO ĐỊNH HƯỚNG ZERO TRUST

Nhịp Workspace & Nhịp Security

Sinh viên: Lê Minh Nhật — Nguyễn Minh Tuấn

Ngày cập nhật: 08/11/2026

Trạng thái: BẢN THẢO ĐÃ KIỂM THỬ LAB. Kết quả thực tế được bổ sung tại phần 9; chưa xác nhận nghiệm thu máy khách thứ hai hoặc diễn tập vận hành đầy đủ.

1. Bài toán và mục tiêu

Khi mỗi ứng dụng tự quản lý tài khoản và phiên riêng, việc thay đổi vai trò, khóa nhân sự nghỉ việc và điều tra truy cập có thể bị phân tán. Đồ án xây dựng hai ứng dụng dùng chung nền tảng danh tính: Web A phục vụ nghiệp vụ nhân viên, Web B phục vụ quản trị và giám sát. Keycloak cung cấp OIDC, SSO và MFA; LDAP đóng vai trò nguồn danh tính cho nhóm tài khoản liên kết.

Mục tiêu thiết kế là xác thực tập trung, phân quyền theo vai trò và phạm vi dữ liệu, kiểm soát vòng đời danh tính, lưu dấu vết truy cập và phát hiện tín hiệu bất thường. Mọi yêu cầu API vẫn phải được kiểm tra dù người dùng đã đăng nhập. Giao diện chỉ hiển thị chức năng theo quyền và không thay thế kiểm tra backend.

Phạm vi gồm lab trên máy chủ và máy khách cùng LAN/VPN riêng, HTTPS bằng CA lab, các vai trò employee, manager, admin và auditor. Đồ án không tuyên bố triển khai đầy đủ Zero Trust doanh nghiệp: chưa có đánh giá thiết bị toàn diện, chính sách rủi ro liên tục, HA hay năng lực chịu tải đã đo kiểm.

2. Yêu cầu chức năng và phân quyền

Vai trò	Chức năng chính	Giới hạn
Employee	Hồ sơ, chấm công, đơn điều chỉnh, yêu cầu quyền có thời hạn	Dữ liệu của chính mình; không dùng Web B

Vai trò	Chức năng chính	Giới hạn
Manager	Chức năng cá nhân, công/đơn của nhóm, duyệt quyền nhóm phù hợp	Không đọc nhóm khác, không tự duyệt
Admin	Quản trị danh tính, JCL, xử lý phiên/MFA, phê duyệt, monitoring	Tài khoản admin/chính mình được bảo vệ theo từng thao tác
Auditor	Nhật ký, phân tích, rà soát quyền, nhãn đánh giá detector	Không sửa tài khoản, cấu hình luật hay xử lý incident quản trị

Web A và Web B dùng client/audience riêng. Token Web B không được sử dụng cho các API chấm công Web A. Một user không có đúng vai trò sẽ bị API từ chối, kể cả khi gọi trực tiếp đường dẫn hoặc chỉnh giao diện.

3. Kiến trúc triển khai

Frontend React/Vite dùng chung thành phần giao diện và API client. Backend Express chạy Node.js 22, xác minh JWT bằng JWKS, kiểm tra phiên/tài khoản Keycloak và trạng thái cục bộ. SQLite duy trì nghiệp vụ, grant, workflow, hold, thông báo, audit và hàng đợi gửi audit.

Keycloak dùng PostgreSQL riêng cho dữ liệu danh tính. OpenLDAP phục vụ LDAPS; federation READ_ONLY và mapping nhóm được cấu hình qua scripts tuần 6. Audit Service Python dùng PostgreSQL khác, nhận sự kiện chuẩn hóa từ backend qua token máy chủ. Python worker đọc kho audit để sinh dự đoán và incident.

Gateway HTTPS phục vụ hai ứng dụng và chuyển tiếp đến các dịch vụ nội bộ. Máy thứ hai phải tin CA lab và dùng hostname/IP hợp lệ trong chứng chỉ. Việc hai máy truy cập chung IAM không đồng nghĩa chia sẻ cookie SSO; mỗi hồ sơ trình duyệt có phiên riêng.

Các sơ đồ thành phần/trust boundary và sequence OIDC, SSO, JCL, Audit được lưu tại docs/KIEN_TRUC_VA_LUONG_HE_THONG.md. Đây là sơ đồ thiết kế dựng từ mã nguồn, không phải ảnh minh chứng chạy hệ thống.

4. Xác thực, MFA và quản lý phiên — tuần 5

Luồng đăng nhập dùng Authorization Code với PKCE S256. Backend xác minh chữ ký, issuer, audience, thời hạn và client hợp lệ. Khi gọi API, hệ thống còn xét vai trò, phạm vi nhóm/chủ sở hữu, required actions, MFA policy, cutoff thu hồi và phiên Keycloak.

MFA được áp dụng theo flow/cờ quản lý bởi admin, không cho người dùng tự sửa cờ để bỏ yêu cầu. Khôi phục MFA yêu cầu xác thực lại gần thời điểm thao tác và ghi nhận cơ sở xác minh. Không lưu OTP hoặc secret MFA vào nhật ký.

Backend kiểm tra tài khoản/phiên từ nguồn, có cache ngắn theo thiết kế hiện có. Khi Keycloak không liên lạc được, không bỏ qua kiểm tra để cho phép truy cập. Logout và thu hồi phiên phải được kiểm thử hai chiều giữa Web A và Web B; tab nền và cache có thể làm UI cập nhật chậm hơn phản hồi API.

5. Liên kết LDAP — tuần 6

OpenLDAP lưu người dùng và nhóm nghiệp vụ. Keycloak federation dùng LDAPS, chế độ READ_ONLY và mapper để chuyển nhóm nguồn thành vai trò ứng dụng. Một danh tính LDAP phải có trạng thái và cấu hình nhóm phù hợp; thiếu hoặc nhiều nhóm nghiệp vụ mâu thuẫn không được tự suy diễn thành quyền mở rộng.

Nguồn LDAP quản lý thuộc tính của user liên kết. Các API sửa trực tiếp hồ sơ/role không được dùng để vượt qua chính sách read-only. Web B cung cấp danh bạ, ánh xạ nhóm và các lượt đồng bộ có trạng thái. Lỗi đồng bộ được hiển thị thay vì giả định đã cập nhật thành công.

Script chuẩn bị tạo credential/cert/LDIF riêng trong thư mục ignored. Script setup có backup và kiểm tra tiền điều kiện. Đã chuẩn bị, áp dụng federation, full sync và kiểm thử đăng nhập LDAP/MFA cùng vòng đời nguồn thật ngày 08/11/2026.

6. Quản trị vòng đời và quyền — tuần 7

Join/Change/Leave là workflow có yêu cầu, phê duyệt, snapshot trước/sau, version và lịch sử. Execute không đồng nghĩa đã hoàn tất. Khi bắt đầu thay đổi tài khoản hiện có, backend giữ hold, nâng cutoff thu hồi, thu hồi grant liên quan và chặn thao tác quản trị cũ mâu thuẫn.

Với user local, backend thực hiện qua Keycloak có marker để không tạo trùng user khi retry. Với user LDAP, operator CLI ghi nguồn theo workflow đã duyệt; ứng dụng không tự gọi lệnh hệ thống từ trình duyệt. Sau receipt nguồn, backend full sync rồi đọc lại metadata/role/trạng thái và phiên để đối chiếu.

Nếu một bước không chắc chắn, workflow partial/failed giữ hold. Chỉ đối chiếu thành công mới chuyển sang active hoặc left; không mở tài khoản bằng cách sửa trạng thái trực tiếp. Đây là cách phối hợp nhiều hệ thống có khả năng lỗi, không phải transaction phân tán.

Yêu cầu quyền ứng dụng có resource, phạm vi và thời hạn. Grant không nâng role nền tảng. Manager chỉ duyệt phạm vi nhóm phù hợp; admin có phạm vi rộng hơn nhưng không tự duyệt yêu cầu của mình. Expiry/revoke được kiểm tra ở API tài nguyên. Review quyền lưu snapshot và khuyến nghị, không âm thầm thu hồi chỉ từ một finding.

7. Audit tập trung — tuần 8

Audit PostgreSQL được tách khỏi DB nội bộ Keycloak. Nguồn gồm API Web A/Web B, Keycloak user events và admin events. Bản ghi chuẩn hóa có event ID, thời điểm, source, user/client, session hash, action/resource, decision, HTTP status, IP và request ID. Details chỉ gồm các trường được cho phép.

SQLite outbox được ghi cùng transaction với sự kiện ứng dụng. Sender gửi batch và chỉ đánh dấu delivered sau ACK. PostgreSQL dùng khóa duy nhất event ID để gửi lại không tạo thêm dòng cùng ID. Source UUID được giữ trong SQLite để không đổi danh tính sự kiện khi restart hoặc restore phù hợp.

Collector có checkpoint, cửa sổ thời gian, offset, overlap và retry. Backfill chỉ trong thời hạn nguồn còn giữ. Khi khoảng ngắt có thể vượt retention, hệ thống ghi gap cần đối chiếu. Không thể tuyên bố không mất log end-to-end trước khi kiểm thử trường hợp lỗi, dữ liệu đến muộn, nguồn phân trang thay đổi và dung lượng ổ đĩa.

Web B hỗ trợ tra cứu, phân trang, CSV có giới hạn hiển thị rõ, account timeline theo bộ lọc user, correlation theo request/session, tổng quan ALLOW/DENY và cảnh báo. Incident có trạng thái, note, actor và version. Retention mặc định tắt, có xem trước và xác nhận riêng; giữ bản ghi thuộc incident chưa đóng.

8. Phát hiện bất thường — tuần 9

Baseline Python áp dụng luật có giải thích. Các tín hiệu gồm login failure burst, employee thử API admin, DENY liên tiếp, IP mới, ngoài giờ, token đã thu hồi và request spike. Đặc trưng dùng cửa sổ theo event-time, với tie-break sequence để xử lý timestamp bằng nhau.

Worker có job/config snapshot, checkpoint và transaction cho kết quả. Mỗi batch tối đa 200 bản ghi; tự động mặc định tắt. Output gồm Normal/Anomaly, luật khớp, features, version, latency và processing time. Anomaly cần điều tra; Normal không khẳng định an toàn. Không dùng dự đoán để tự thay đổi quyền hoặc khóa user.

Nhãn đánh giá phải dựa trên kịch bản và bằng chứng độc lập. Cùng nhóm scenario không được xuất hiện ở cả train và evaluation. Các trường gần trùng khác scenario vẫn cần người đánh giá rà soát. Tập evaluation được snapshot và băm khi tính chỉ số; nhãn sửa sau đó không làm thay đổi snapshot cũ.

Precision = TP/(TP+FP); Recall = TP/(TP+FN); F1 = 2TP/(2TP+FP+FN); False Positive Rate = FP/(FP+TN). Mẫu số bằng 0 được hiển thị chưa xác định. Latency gồm thời gian từ sự kiện đến phát hiện, kể cả collection/backfill; processing time là thời gian chạy batch. Hai đại lượng không được đánh đồng.

Isolation Forest/ML là hướng mở rộng tùy chọn khi có dữ liệu đủ chất lượng. Không huấn luyện hay đánh giá mô hình bằng chính nhãn sinh ra từ luật rồi coi đó là bằng chứng độc lập.

9. Kế hoạch kiểm thử và trạng thái bằng chứng

Đã chạy trên Keycloak/OpenLDAP/PostgreSQL và HTTPS thật ngày 08/11/2026. Chi tiết từng suite và bằng chứng: docs/KET_QUA_KIEM_THU_2026_11_08.md.

Phạm vi	Kết quả
Backend / tiện ích frontend / Python	130/130; 8/8; 7/7
SSO / UI / nghiệp vụ	29/29; 42/42; 24/24
LDAP/API mới / JCL local / JCL LDAP	20/20; 24/24; 23/23
Audit/Detection / session-LDAP / HTTP probes	100/100; 9/9; 5/5

Phạm vi	Kết quả
Màn hình mới desktop/mobile	19/19
Build Web A/B, compileall, diff check	Đạt

Thí nghiệm 27 mẫu mô phỏng định nhãn trước suy luận: TP7, TN20, FP0, FN0; Precision/Recall/F1 1,0 và FPR 0. Đây là kiểm tra chức năng bảy luật, không phải bằng chứng độ chính xác trên dữ liệu doanh nghiệp. Timestamp mô phỏng thuộc quá khứ nên latency gồm thời gian lấy bù; không dùng số này làm tốc độ realtime.

Đã phục hồi Audit riêng và đọc được 2.754 events, 2.693 kết quả, 1 evaluation tại thời điểm backup. Video giới thiệu màn hình và ảnh thật nằm tại evidence/release. Chưa có xác nhận mới từ máy vật lý thứ hai; chưa diễn tập chuyển toàn bộ các kho sang môi trường khác.

10. Tích hợp và bàn giao — tuần 10

Đã chuẩn bị runner yêu cầu cấu hình LDAP/audit, Compose overlay, backup đa kho, restore Audit vào project mới, source package có manifest SHA-256, sơ đồ, báo cáo, slide và kịch bản video. Không bổ sung công nghệ lớn ở giai đoạn này; tập trung khớp cấu hình, trạng thái, quyền và tài liệu.

Backup dữ liệu khác với ZIP source. Snapshot các kho riêng chỉ bảo đảm tính nhất quán từng kho; để phục hồi phối hợp phải quiesce writer và ghi nhận rõ. Phục hồi trước vào môi trường cô lập, giữ hold/cutoff, đối chiếu source và replay audit khi cần, sau đó mới quyết định chuyển endpoint.

Release đã chạy và kiểm thử trong lab, có ảnh/video, snapshot đánh giá và restore Audit. Còn xác nhận thiết bị vật lý thứ hai và diễn tập vận hành cuối. Mốc chính thức 4/6; không tự nâng thành 6/6.

11. Đánh giá giới hạn và hướng phát triển

Điểm thiết kế đáng chú ý là kết hợp kiểm tra danh tính tập trung với trạng thái ứng dụng, hold trong workflow nhiều hệ thống, audit outbox và detector giải thích được. Các thí nghiệm lab đã xác nhận những luồng nêu ở phần 9; khả năng vận hành quy mô lớn vẫn cần đo riêng.

Giới hạn gồm lab một backend, SQLite nghiệp vụ, HTTP server nội bộ cho audit, chưa có HA/tải đo được, tài khoản Audit DB lab chưa tách migration/runtime, outbox chưa có tự dọn, dữ liệu đến muộn có thể làm phân tích thiếu cửa sổ và chất lượng nhãn phụ thuộc người đánh giá. Các điểm này phải được giữ trong phần hạn chế của báo cáo cuối.

Hướng mở rộng gồm phân quyền DB tối thiểu, observability/retention theo dung lượng, replay có kiểm soát, queue và worker chuyên dụng khi cần mở rộng, risk policy có device context, và ML khi có dataset độc lập. Không đưa các hướng mở rộng thành chức năng đã có.

12. Tài liệu tham khảo và nguồn triển khai

- Keycloak 26.8 Admin REST API: https://www.keycloak.org/docs-api/26.8.0/rest-api/index.html
- PostgreSQL 17 INSERT/ON CONFLICT: https://www.postgresql.org/docs/17/sql-insert.html
- Psycopg 3 transaction/basic usage: https://www.psycopg.org/psycopg3/docs/basic/usage.html
- Nguồn nội bộ: tuanconlai.md; docs/TUAN_5_TRIEN_KHAI.md đến docs/TUAN_10_TRIEN_KHAI.md; các checklist nghiệm thu; docs/BAN_GIAO_VA_VAN_HANH.md.

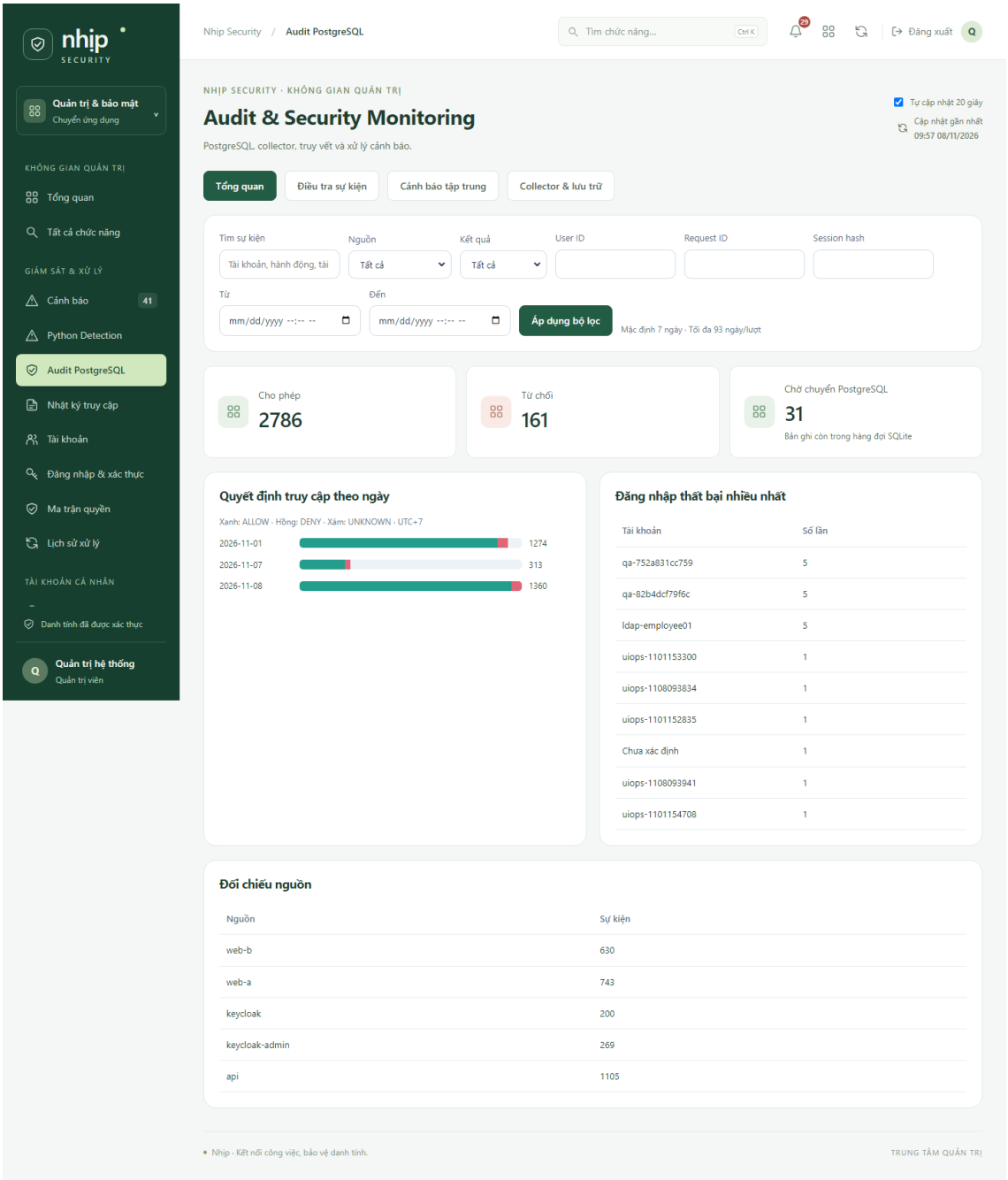
Tài liệu tham khảo phục vụ thiết kế API/transaction; không thay thế kết quả kiểm thử của hệ thống này.

Phụ lục — chỉ dẫn hồ sơ bàn giao

- docs/TUAN_8_TRIEN_KHAI.md
- docs/TUAN_9_TRIEN_KHAI.md
- docs/TUAN_9_NGHIEM_THU.md
- docs/TUAN_10_TRIEN_KHAI.md
- docs/KIEN_TRUC_VA_LUONG_HE_THONG.md
- docs/BAN_GIAO_VA_VAN_HANH.md
- docs/KICH_BAN_DEMO_VA_VIDEO.md

Kết quả thực tế: docs/KET_QUA_KIEM_THU_2026_11_08.md. Dataset mô phỏng, ảnh và video thao tác được lưu tại evidence/release; chưa thay bằng chứng máy vật lý thứ hai.

Audit PostgreSQL trên lab HTTPS



Kết quả trên 27 mẫu mô phỏng; không suy rộng thành độ chính xác vận hành

